



Utkarsh Arora <utkarsh20143@iiitd.ac.in>

Report issue - Group 7

1 message

Google Forms <forms-receipts-noreply@google.com>
To: utkarsh20143@iiitd.ac.in

Sat, Dec 3, 2022 at 1:04 AM

Thanks for filling out [Report issue - Group 7](#)

Here's what was received.

Report issue - Group 7

Please fill out this form to report an issue/vulnerability in the group 7.

Your email (utkarsh20143@iiitd.ac.in) was recorded when you submitted this form.

Vulnerability type

*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☐ Feature bug

☒ Other: DOS

Steps to reproduce

*

Describe the steps to reproduce the vulnerability.

The website uses an apple mail to send OTP requests.

OTP requests are used in two places: to register and to login

While the website has made sure that the same user cannot request for OTPs very quickly in a short span of time for login; different users can register very quickly in a short span of time, and request for OTP.

Essentially, I can register with different email ids in a very quick succession of time, and the website won't rate limit my IP.

This will result in OTP requests being spammed in a very short span of time.

Apple mail has a limit of 1000 mails per day.

When this limit is reached, no more mails can be generated, thus blocking both the registration and login functionality for 24 hours

Proof of concept

*

Provide a proof of concept for the vulnerability.

I registered myself on the website

I intercepted the POST request using Burpsuite

I used that to write a python script to spam the website the POST request that generated the OTP

Thus, when the limit was reached, the website cannot send out any more OTPs.

Therefore, no user can register to the website, and no user can log in to the website, for 24 hours

Impact

*

Describe the impact of the vulnerability. How bad is it?

High severity. No new user can register on the website, and no existing user can log in to the website for 24 hours. Therefore, essentially the website is for all purposes unusable for 24 hours. This same attack can be done the next day as well, so the website can essentially stay useless forever.

Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

Submitted files



fcs_7_1_1 - Utkarsh Arora.png



fcs_7_1_2 - Utkarsh Arora.png

Create your own Google Form

Report Abuse